

관리자 권한 · 운영 접근 범위

Herfree · 2026년 7월 · 실제 코드 기준

1. 역할 종류

USER	일반 회원 — 커뮤니티·일지·마이페이지
MODERATOR	운영 스태프 — 신고·콘텐츠 숨김·비공개 게시판 열람
ADMIN	관리자 — 회원 상태·정지·닉네임 초기화 등
SUPER_ADMIN	최고 관리자 — 역할 변경 등
CREATOR / DOCTOR	칼럼·콘텐츠 작성 권한 (커뮤니티 일반 글과 분리)

2. 운영자(스태프)가 할 수 있는 것

- 공개·비공개 게시판 글·댓글 열람 (비밀사연, 1:1 상담, 운영 문의 포함)
- 신고 처리 — 게시글·댓글 숨김·삭제
- 회원 계정 정지·해제 (ADMIN 이상)
- 회원 닉네임 초기화 (ADMIN 이상)
- 공지·칼럼·유튜브·제품 등 운영 콘텐츠 관리
- 일지 건수·익명 집계 통계 (관리자 대시보드)

3. 운영자가 하지 않는 것 (현재 구현)

- 개별 회원 건강 일지 원문 조회 API 없음
- 회원 이메일·비밀번호 평문 조회 없음
- 임의 DB 직접 수정 (운영 정책상 금지, API·관리 화면만)

4. 감사 · 기록

admin_audit_logs	관리자 주요 조작 기록
role_audit_logs	역할 변경 기록

5. 보안 (현재 · 검토 필요)

적용	관리 API JWT 인증, 역할별 권한 분리
미적용	관리자 2단계 인증(MFA) — 오픈 전 보완 검토 항목

처리방침 「운영자 필요 범위 접근」과 위 실제 범위의 일치 여부는 법률 검토 체크리스트 D-4에서 확인.

